ITA CHALLENGE SPRINT · SEMANA 1 · DIAGNÓSTICO DO PROBLEMA

A empresa registra o uso de IA. Não consegue confiar no registro.

Governança de informação em ferramentas de IA no Stark Bank. Nesta primeira semana definimos o problema, provamos que ele existe na própria base da empresa e recortamos o que cabe no Sprint.

GERENCIA · RASTREABILIDADE E GOVERNANÇA DE IA · BASE OFICIAL: 650 EVENTOS · 72 USUÁRIOS · 8 FERRAMENTAS · 14 REGRAS

A DECISÃO QUE PRECISA MELHORAR

Como o Compliance decide o que é risco — e como audita essa decisão depois.

Hoje cada uso de IA já chega com uma classificação de risco e uma regra citada. Mas a classificação é **confiada, não verificada**, e não há linhagem que ligue uma informação às ferramentas e às pessoas por onde ela passou.

Hoje

Log de atividade

“O usuário X acessou a ferramenta Y às 14h.” O registro existe, mas responde à pergunta errada e ninguém confere se a regra citada corresponde ao que aconteceu.

Recorte proposto

Linhagem da informação

“A chave/API secret apareceu em 5 ferramentas, com 30 pessoas, 35 vezes — 3 em IA pública.” A busca começa no documento, reaplica a política e audita a rotulagem.

POR QUE É RELEVANTE PARA O NEGÓCIO

Fintech regulada. O que vaza para uma IA pública não volta.

O Stark Bank opera sob LGPD e regulação bancária. O material que transita nas ferramentas de IA é exatamente o mais sensível — e a exposição é jurídica, de segurança e de propriedade intelectual ao mesmo tempo.

Dado pessoal · CPF

LGPD: obrigação de resposta de privacidade e possível comunicação ao titular e à ANPD.

Chave / API secret

Credencial exposta é acesso a sistema. Risco crítico em qualquer ferramenta, aprovada ou não.

Financeiro não divulgado

Informação material antes da hora — risco regulatório e de mercado.

Código confidencial

Propriedade intelectual do banco entregue a um modelo de terceiro.

Ferramenta não aprovada

12,3% dos usos ocorrem fora das ferramentas homologadas pela empresa.

IA pública

Conteúdo enviado pode alimentar treino e sair do controle do banco para sempre.

COMPROVAÇÃO POR EVIDÊNCIAS · AUDITORIA DA BASE OFICIAL

O problema não é hipótese. Está na base que a própria empresa entregou.

Reaplicamos as 14 regras da política aos 650 eventos e auditamos a rotulagem já existente. Seis achados, todos verificáveis célula a célula na planilha:

A-01	38	Eventos citam regra de “ferramenta aprovada”, mas ocorreram em **IA pública**. O nível pode estar certo; a trilha de auditoria induz o auditor a erro.
A-02	18	Fechados com regra genérica onde há regra específica (R04/R05/R06). A obrigação de LGPD desaparece do registro.
A-03	8	Conteúdo interno/confidencial no gerador de imagens “só público”. Deveriam ser Alto e virar alerta — não viraram.
A-04	6/14	Regras que **nunca disparam**. A política aparenta 14 controles e opera com 8.
A-05	47	Alertas “tratados” **sem data de tratamento**. O SLA de 24h é declarado, não medido.
A-06	38	Combinação que **nenhuma regra** cobre. Lacuna de política — propomos a regra R15.

COMPROVAÇÃO POR EVIDÊNCIAS · O NÚMERO QUE DECIDE

7 de 10

indicadores que a empresa **declara** divergem do que a base realmente mostra quando recalculada.

6,8% → 16,6%

Eventos **críticos**: a empresa subnotifica a própria exposição em ~2,4×.

61 → 72

Usuários ativos com IA: 11 pessoas a mais do que o painel oficial conta.

72% → ?

"Alertas tratados em 24h": **não apurável** — não existe carimbo de tempo.

Quando a decisão de governança se apoia num painel que erra por 2,4× para menos, a empresa acredita estar mais segura do que está.

QUEM É IMPACTADO

Cinco frentes, uma cadeia só.

Compliance / DPO

Audita sobre uma trilha que confunde registro com evidência. Precisa provar o fluxo, não só listá-lo.

Segurança / CISO

Segredos e código expostos a terceiros, sem visão de qual informação saiu por onde.

72 usuários · 12 áreas

Usam IA no trabalho real. Sem regra clara e consequência definida para os casos comuns.

Direção / Conselho

Toma decisão de risco sobre indicadores que erram por 2,4×. Exposição regulatória e reputacional.

Clientes / titulares

Dados pessoais podem alcançar uma IA pública sem a resposta de privacidade que a LGPD exige.

O elo que falta

Ninguém consegue, hoje, partir de uma informação e ver toda a sua trajetória. É esse elo que o projeto entrega.

QUAL IMPACTO O PROBLEMA GERA

O custo de não enxergar.

Regulatório

Dado pessoal em IA pública sem a resposta de privacidade prevista — exposição a LGPD e à regulação bancária, com a obrigação sumindo do registro (A-02).

Segurança / PI

Credenciais e código confidencial entregues a modelos de terceiros, sem trilha de qual informação, de quem, por onde.

Decisão sobre dado errado

Governança apoiada num painel que subnotifica o risco crítico em 2,4× e mede SLA que não é apurável.

Auditoria não conclusiva

A política aparenta 14 controles e opera com 8; a trilha induz o auditor a erro. Uma auditoria real não fecha.

O RECORTE DO PROJETO

O que cabe no Sprint — e o que fica de fora.

DENTRO DO PROTÓTIPO

- → **Busca reversa da informação** — do documento para as ferramentas e pessoas.
- → **Reaplicação da política** com ordem de precedência declarada e cadeia de evidências.
- → **Auditoria da rotulagem** existente: os seis achados e os indicadores recalculados.
- → **Alertas** por nível de risco, com filtros por área, usuário, ferramenta e período.
- → **Captura na borda** (extensão + sensor) como "presente", unificada ao legado da planilha.

FORA DO PROTÓTIPO

- × **Bloqueio ativo** (prevenção em linha). O sistema observa e governa; não interrompe o uso.
- × **Leitura de conteúdo cifrado** (MITM). O sensor registra metadado, nunca o texto.
- × **Detecção de paráfrase** no fingerprint — pega recorte e colagem, não reescrita.
- × **Integração de produção** com SIEM/IdP — mostramos o contrato, não a ligação final.
- × **Substituir o DLP** corporativo — demonstramos a camada, não trocamos a existente.

COMO ISTO RESPONDE AO CRITÉRIO DA SEMANA 1

Relevância e clareza do problema.

01 **Compreensão do problema**

Reenquadrado: o problema não é registrar uso, é **confiar no registro** e ter linhagem da informação.

02 **Relevância para o negócio**

Fintech sob LGPD e regulação bancária; o que transita nas IAs é o material mais sensível do banco.

03 **Comprovação por evidências**

Seis achados verificáveis e 7 de 10 indicadores divergentes — na própria base oficial, não em suposição.

04 **Recorte do projeto**

Rastreabilidade, reaplicação da política, auditoria e alertas sobre a base — bloqueio e MITM fora do escopo.